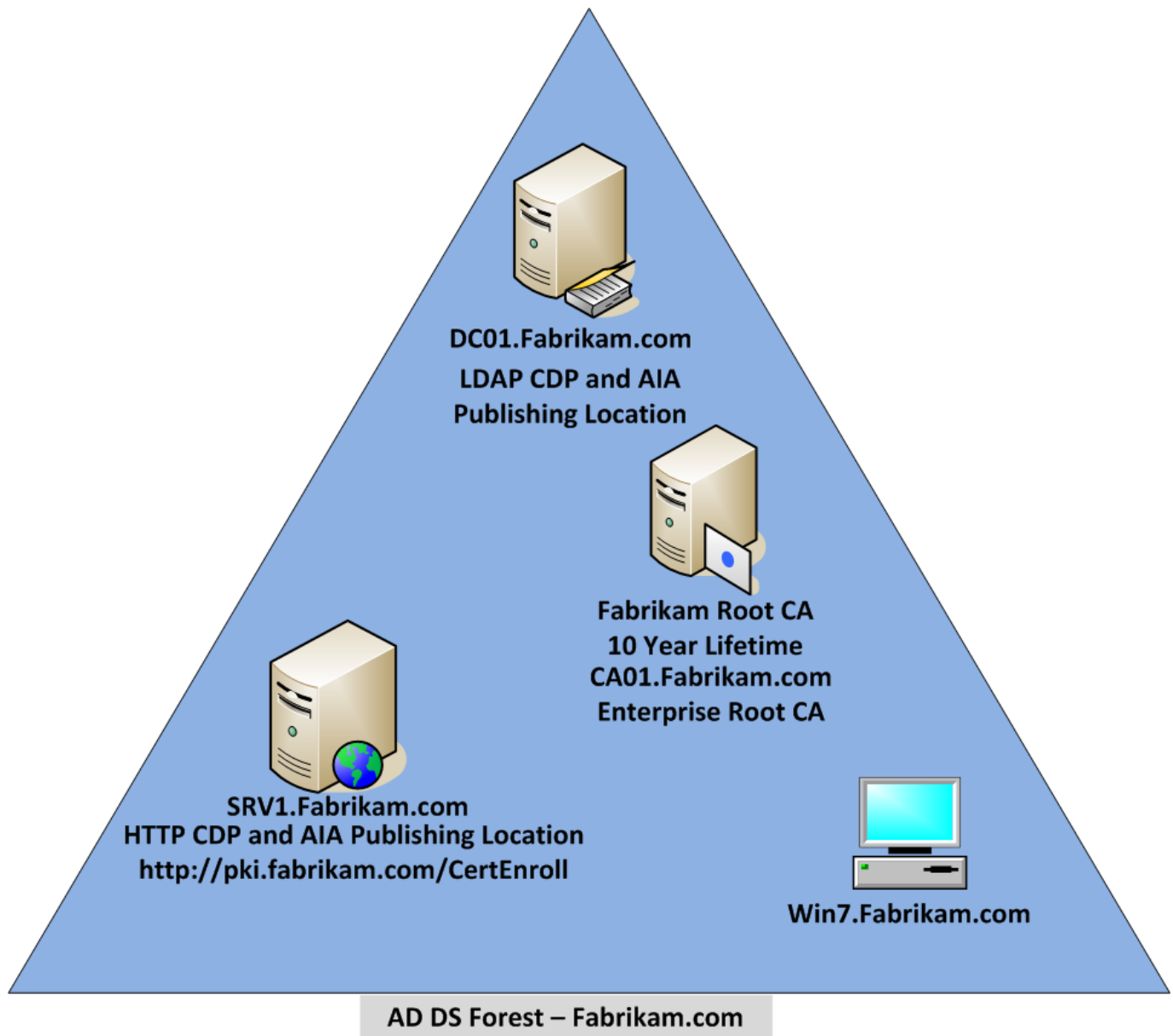


Einfache PKI-Lab-Umgebung mit AD CS (Single-Tier PKI)

Implementierung einer AD-integrierten single-tier CA. Dokumentieren Sie diese in Form eines HowTo. Prüfen Sie vorab die Voraussetzungen (Name, ADDS, DNS, IIS)!

1. Lab-Überblick



Wir verwenden vier virtuelle Maschinen im gleichen Subnetz:

- DC01 – Domain Controller
- CA01 – Root CA
- SRV1 – IIS Webserver
- WIN01 – Client

IP-Adressen:

- DC01.corp.example.com: 192.168.1.10/24
 - CA01.corp.example.com: 192.168.1.11/24
 - SRV1.corp.example.com: 192.168.1.13/24
 - WIN01.corp.example.com: 192.168.1.14/24
-

2. DC01 vorbereiten (Active Directory + DNS)

2.1 Servernamen und IP einstellen

1. Computernamen ändern auf DC01
2. IP-Adressen konfigurieren wie oben geschrieben
3. neustarten

Internet Protocol Version 4 (TCP/IPv4) Properties

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address:

IP address: 192 . 168 . 1 . 10

Subnet mask: 255 . 255 . 255 . 0

Default gateway: . . .

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses:

Preferred DNS server: 192 . 168 . 1 . 10

Alternate DNS server: . . .

☒ Validate settings upon exit

Advanced...

OK Cancel

2.2 Forest/Domain corp.example.com erstellen

1. Im Servermanager domain installieren wie sonst auch
2. Domain = corp.example.com
3. neustarten

3. SRV1 vorbereiten (IIS / HTTP CDP & AIA)

3.1 SRV1 IP setzen und zur Domäne joinen

1. IP-Adressen konfigurieren so wie oben angeschrieben
2. Computernamen ändern
3. domain joinen

4. neustarten und dann mit dem Domain Admin anmelden

Internet Protocol Version 4 (TCP/IPv4) Properties

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address:

IP address: 192 . 168 . 1 . 13

Subnet mask: 255 . 255 . 255 . 0

Default gateway: . . .

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses:

Preferred DNS server: 192 . 168 . 1 . 10

Alternate DNS server: . . .

☐ Validate settings upon exit

Advanced...

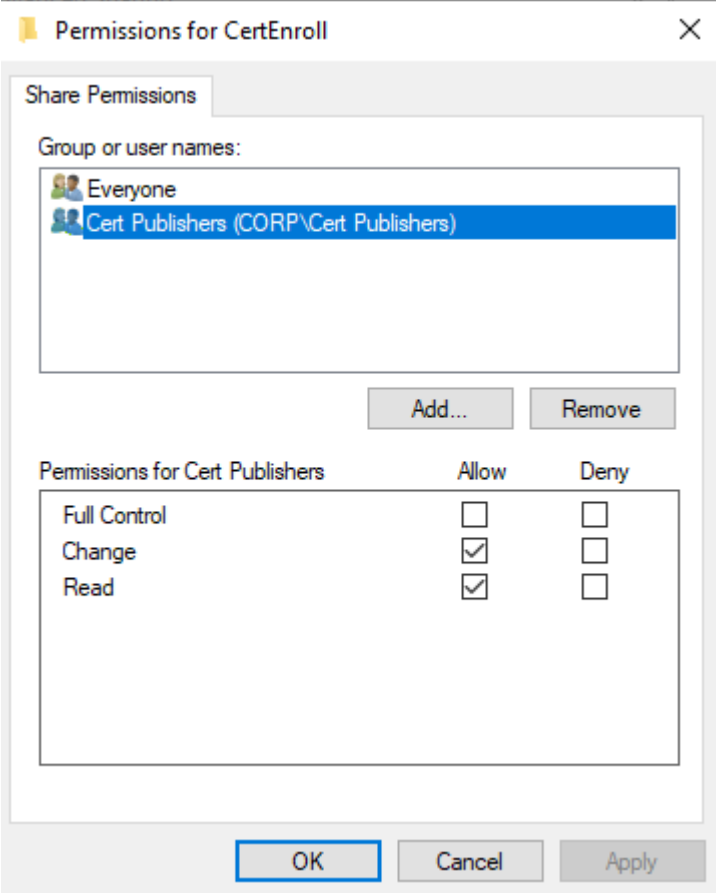
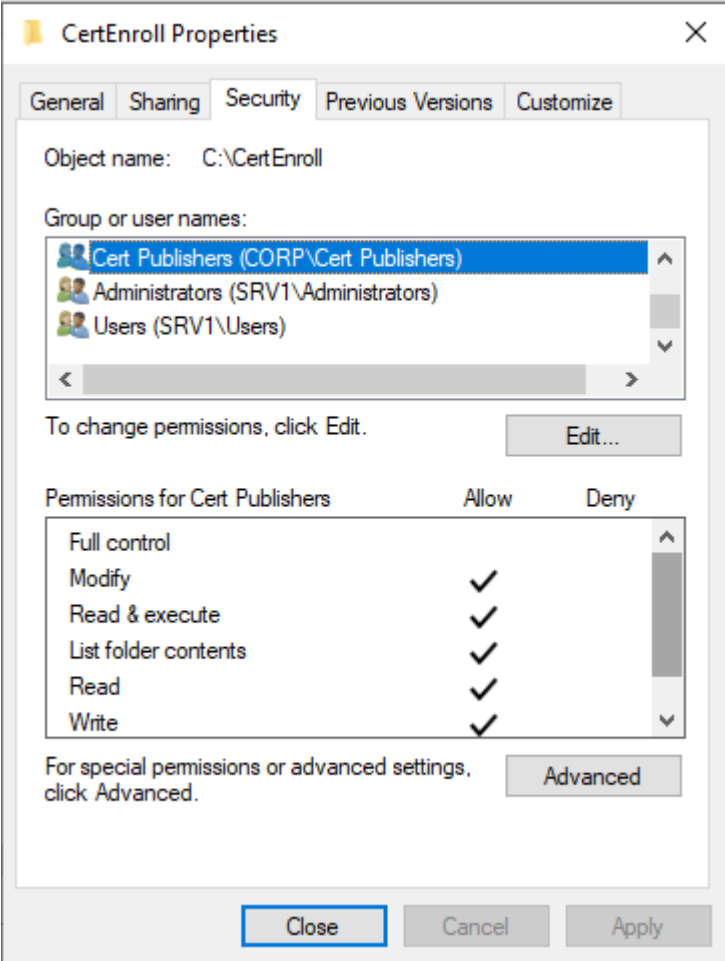
OK Cancel

3.2 IIS Webserver installieren

1. Server-Manager → **Rollen** → **Rollen hinzufügen**.
2. **Webserver (IIS)** auswählen → installieren.

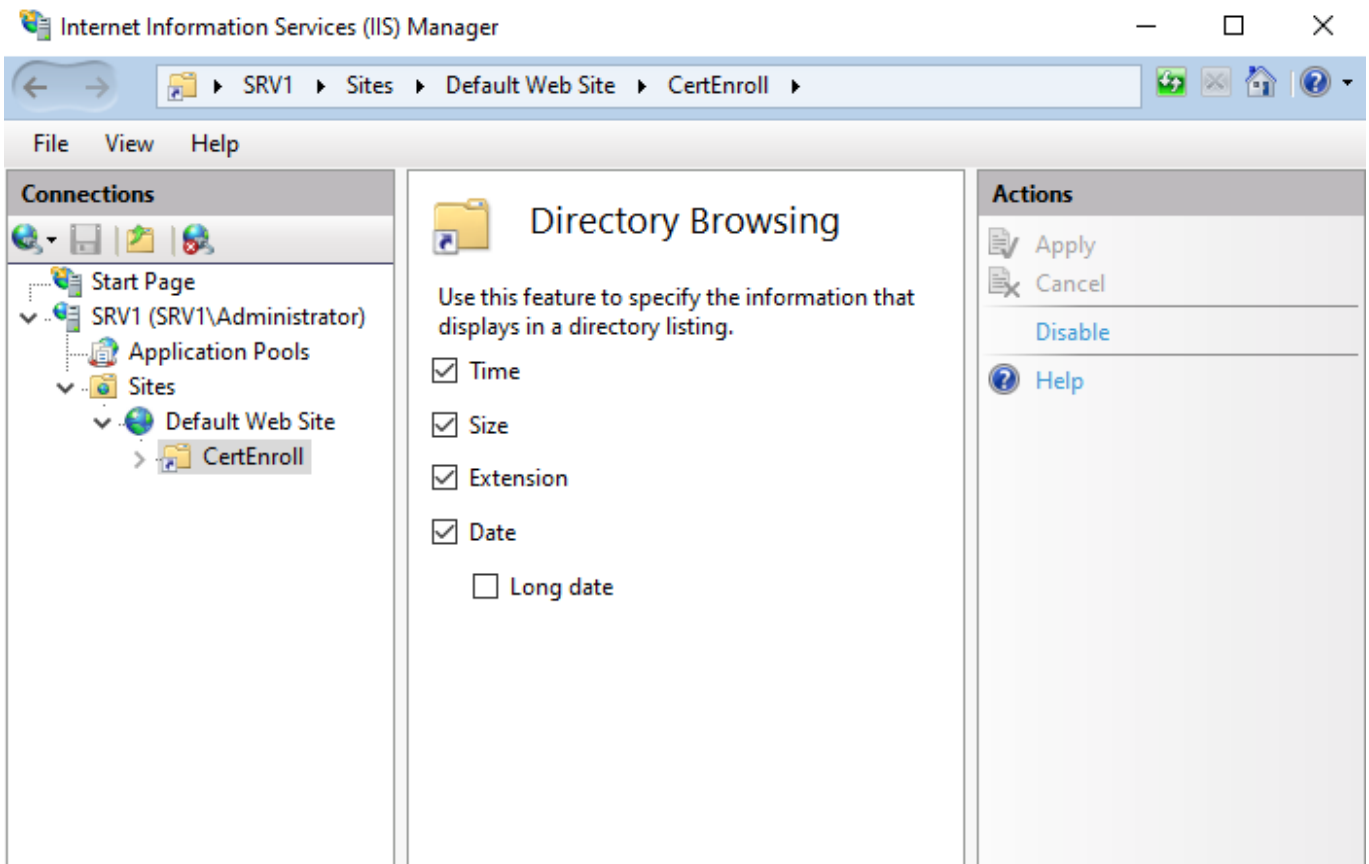
3.3 Ordner und Freigabe C:\CertEnroll

1. Auf SRV1 **C:\CertEnroll** erstellen.
2. Rechtsklick → **Eigenschaften** → Reiter **Freigabe** → **Erweiterte Freigabe**.
 - Haken bei „Diesen Ordner freigeben“.
 - Freigabename: **CertEnroll**.
 - **Permissions** → Gruppe **corp\Cert Publishers** hinzufügen → „Change“ erlauben.
3. Reiter **Security** → **Bearbeiten**:
 - **corp\Cert Publishers** hinzufügen → „Change“ erlauben.



3.4 Virtuelles Verzeichnis in IIS anlegen

1. (IIS)-Manager öffnen.
2. Unter „Sites“ → Default Web Site → Rechtsklick → Virtuelles Verzeichnis hinzufügen....
3. Alias: CertEnroll
Physikalischer Pfad: C:\CertEnroll.
4. Danach in IIS auf CertEnroll → Verzeichnisdurchsuchung → Aktivieren.



3.5 Double Escaping aktivieren (für Delta-CRLs)

1. Eingabeaufforderung als Admin auf SRV1 öffnen.
2. Ausführen:

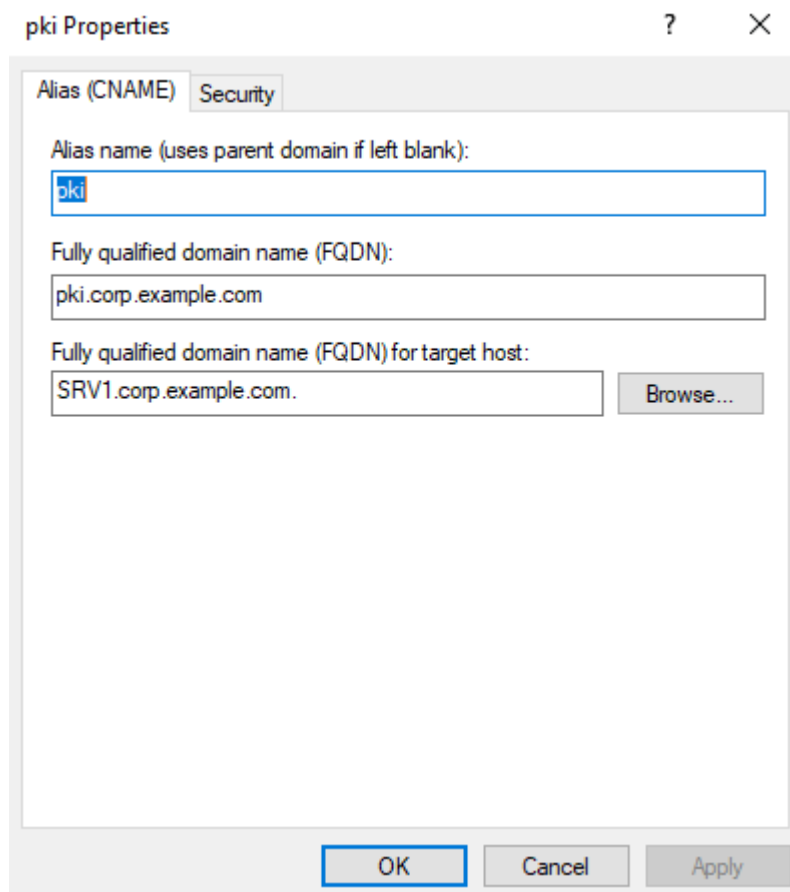
```
cd %windir%\system32\inetsrv
appcmd set config "Default Web Site"
/section:system.webServer/security/requestFiltering -
allowDoubleEscaping:true
iisreset
```

```
C:\Users\Administrator>cd %windir%\system32\inetsrv
C:\Windows\System32\inetsrv> appcmd set config "Default Web Site" /section:system.webServer/security/requestFiltering -allowDoubleEscaping:true
Applied configuration changes to section "system.webServer/security/requestFiltering" for "MACHINE/WEBROOT/APPHOST/Default Web Site" at configuration commit path "MACHINE/WEBROOT/APPHOST/Default Web Site"
C:\Windows\System32\inetsrv> iisreset
Attempting stop...
Internet services successfully stopped
Attempting start...
Internet services successfully restarted
```

Screenshot: CMD mit erfolgreichem `appcmd`-Output.

3.6 DNS-Alias pki.corp.example.com erstellen

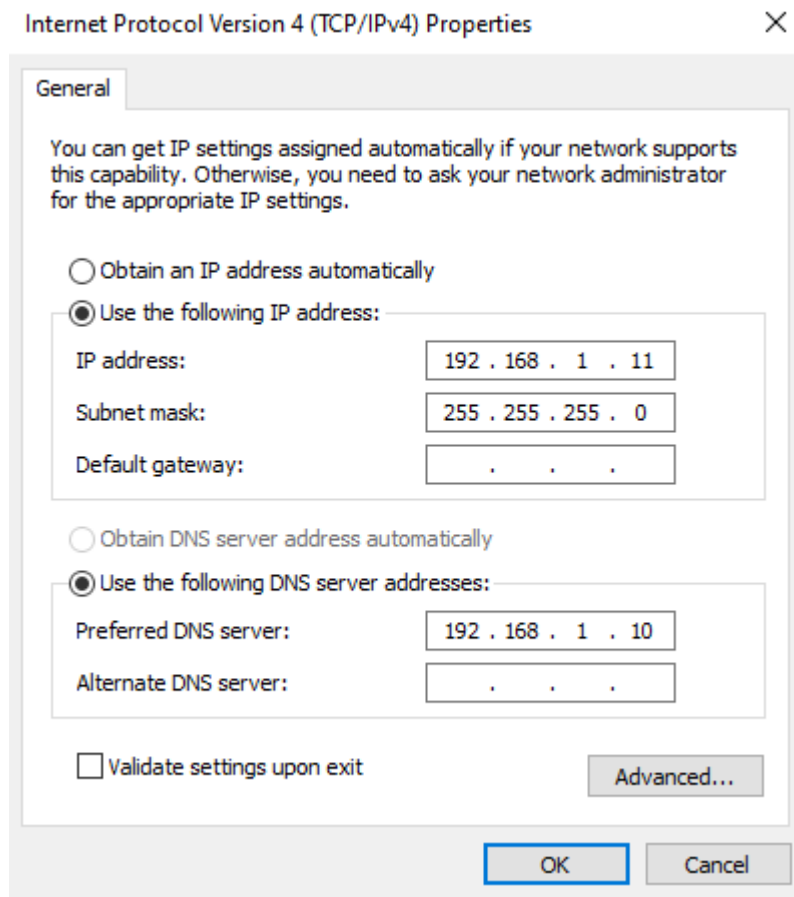
1. Auf DC01 als `corp\Administrator` → `dnsmgmt.msc` starten.
2. Unter Forward Lookup Zone -> In der Zone `corp.example.com` → Rechtsklick → **Neuer Alias (CNAME)**....
3. Aliasname: `pki`
FQDN des Zielhosts: `SRV1.corp.example.com.` (Punkt am Ende nicht vergessen).



4. CA01 vorbereiten (Enterprise Root CA)

4.1 CA01 IP setzen und zur Domäne joinen

1. IP-Adressen konfigurieren so wie oben beschrieben
2. Computernamen ändern + domain joinen
3. neustarten und dann mit dem Domain Admin anmelden



4.2 CAPolicy.inf anlegen

1. Im Ordner `C:\Windows\CAPolicy.inf` eine neue Datei erstellen mit diesem Inhalt:

```
[Version]
Signature="$Windows NT$"

[PolicyStatementExtension]
Policies=InternalPolicy

[InternalPolicy]
OID=1.2.3.4.1455.67.89.5
Notice="Legal Policy Statement"
URL=http://pki.corp.example.com/cps.txt

[Certsrv_Server]
RenewalKeyLength=2048
RenewalValidityPeriod=Years
RenewalValidityPeriodUnits=10
LoadDefaultTemplates=0
AlternateSignatureAlgorithm=1
```

2. Sicherstellen, dass die Datei wirklich `CAPolicy.inf` heißt (.inf, nicht .txt).

4.3 Enterprise Root CA installieren

1. Server-Manager auf CA01 öffnen → **Rollen** → **Rollen hinzufügen**.
2. **Active Directory-Zertifikatdienste** auswählen.
3. Nur **Zertifizierungsstelle** anhängen.
4. Einrichtungsart: **Unternehmens** (Enterprise).
5. CA-Typ: **Stammzertifizierungsstelle**.
6. „Neuen privaten Schlüssel erstellen“.
7. Krypto-Standardwerte belassen.
8. CA-Name: **corp-Root-CA**.
9. Gültigkeitsdauer: **10** Jahre.
10. Standardpfade für DB/Log beibehalten, installieren.

AD CS Configuration

DESTINATION SERVER
CA01.corp.example.com

Confirmation

To configure the following roles, role services, or features, click Configure.

^ **Active Directory Certificate Services**

Certification Authority

CA Type:	Enterprise Root
Cryptographic provider:	RSA#Microsoft Software Key Storage Provider
Hash Algorithm:	SHA256
Key Length:	2048
Allow Administrator Interaction:	Disabled
Certificate Validity Period:	30.11.2035 01:17:00
Distinguished Name:	CN=corp-Root-CA,DC=corp,DC=example,DC=com
Certificate Database Location:	C:\Windows\system32\CertLog
Certificate Database Log Location:	C:\Windows\system32\CertLog

< Previous Next > Configure Cancel

5. Nachkonfiguration der CA (CRLs, AIA/CDP, Auditing)

5.1 CRL-Intervalle setzen

Auf CA01, CMD als Admin öffnen:

```
certutil -setreg CA\CRLPeriodUnits 1
certutil -setreg CA\CRLPeriod "Weeks"
certutil -setreg CA\CRLDeltaPeriodUnits 1
certutil -setreg CA\CRLDeltaPeriod "Days"
```


Hiermit stellt man ein für wie lange die CRL und Delta-CRL gültig sind.

5.2 CRL-Overlap konfigurieren

```
certutil -setreg CA\CRLOverlapPeriodUnits 12  
certutil -setreg CA\CRLOverlapPeriod "Hours"
```

Damit gibt es eine Überlappungszeit, in der Clients eine neue CRL holen können, bevor die alte abläuft.

5.3 Gültigkeit für ausgestellte Zertifikate

```
certutil -setreg CA\ValidityPeriodUnits 5  
certutil -setreg CA\ValidityPeriod "Years"
```

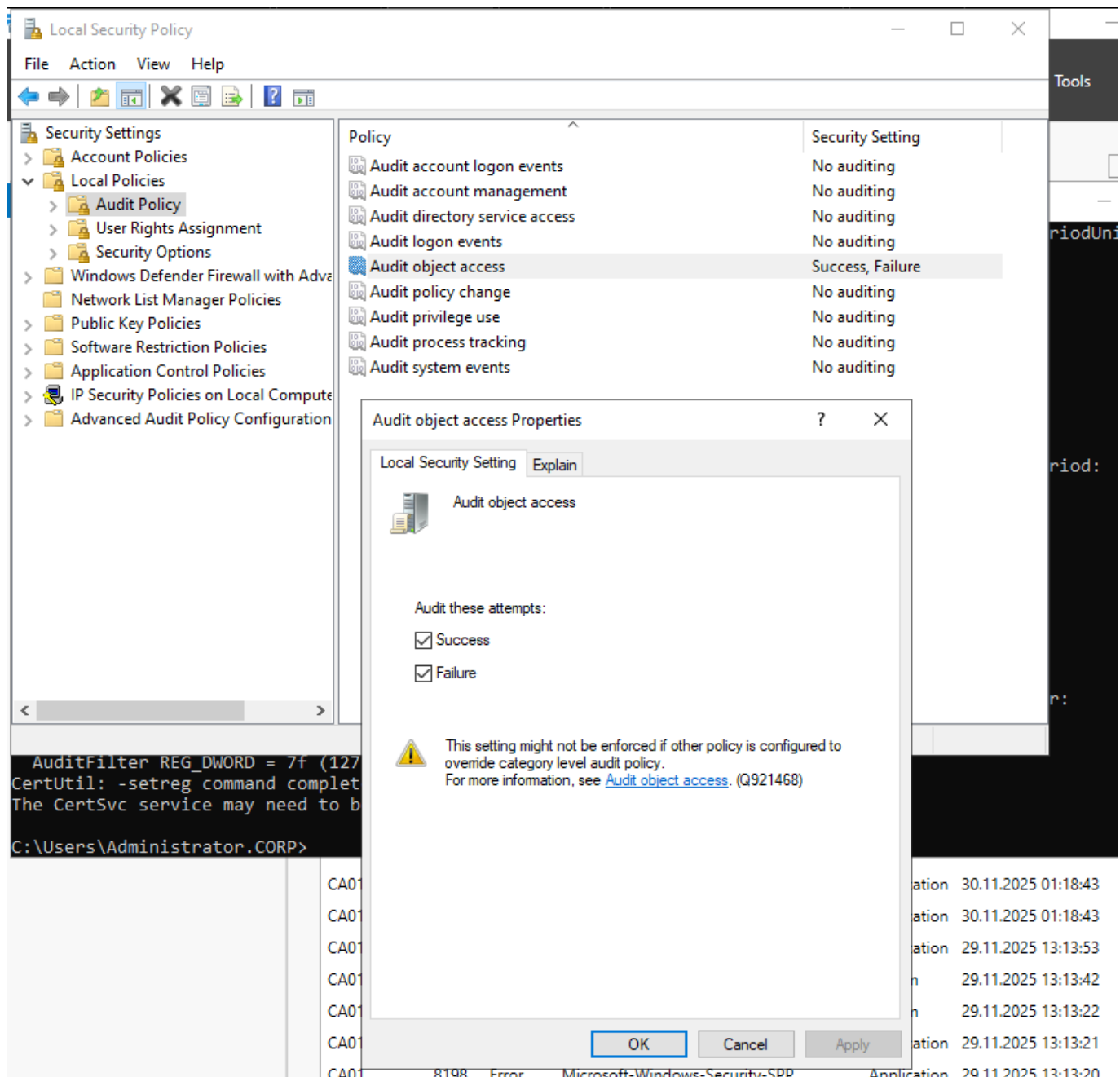
Endentitätszertifikate sollen max. 5 Jahre gültig sein.

5.4 CA-Auditing aktivieren

```
certutil -setreg CA\AuditFilter 127
```

Dann in der lokalen Sicherheitsrichtlinie:

1. **secpol.msc** öffnen.
2. **Lokale Richtlinien** → **Überwachungsrichtlinie**.
3. **Überwachung des Objektzugriffs** → Erfolg + Fehler aktivieren.



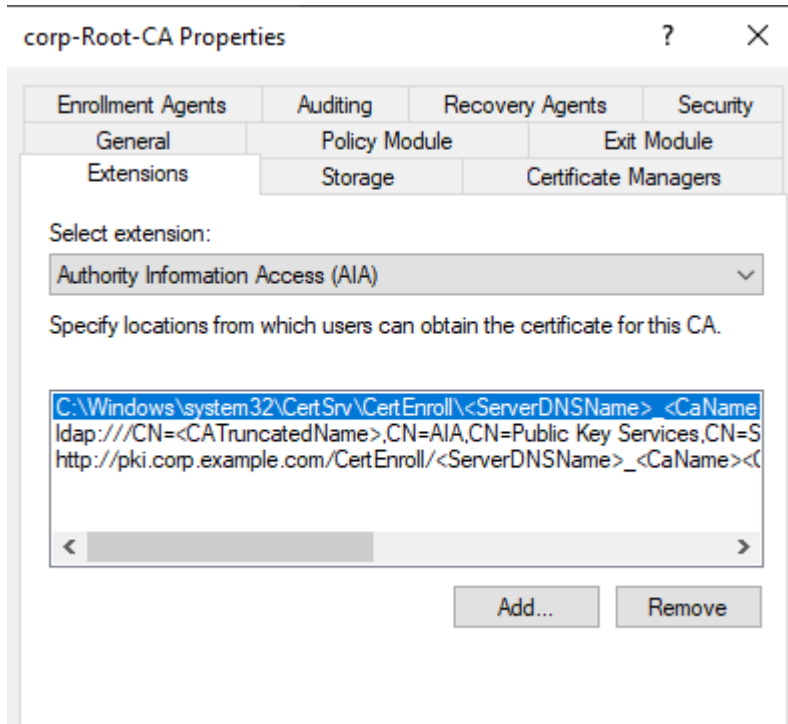
6. AIA- und CDP-URLs konfigurieren

6.1 AIA (Authority Information Access)

Auf CA01:

```
certutil -setreg CA\CACertPublicationURLs ^
"1:C:\Windows\system32\CertSrv\CertEnroll\%1_%3%.crt\n2:ldap:///CN=%7,CN=AIA,CN=Public Key
Services,CN=Services,%6%11\n2:http://pki.corp.example.com/CertEnroll/%1_%3%.crt"

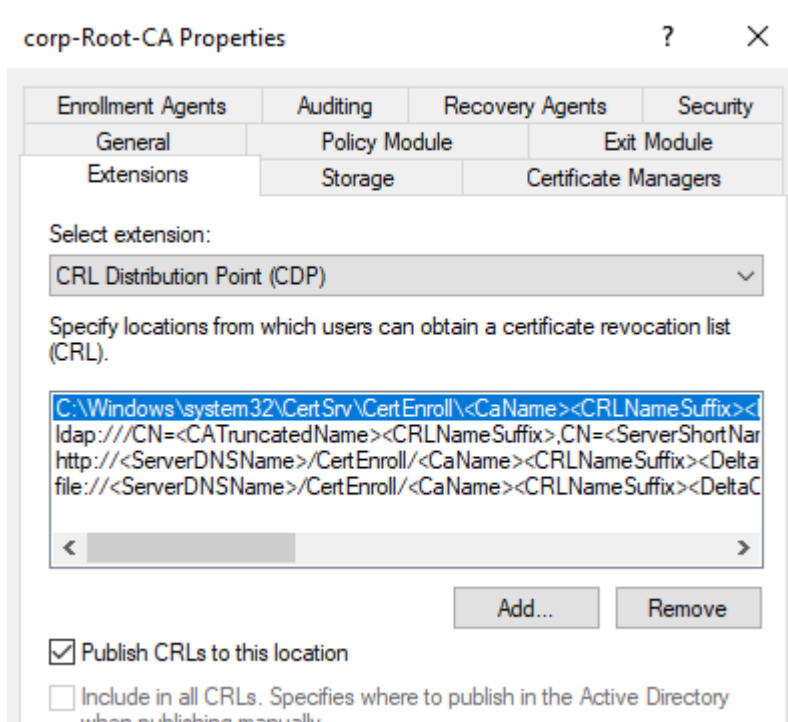
certutil -getreg CA\CACertPublicationURLs
```



6.2 CDP (CRL Distribution Point)

```
certutil -setreg CA\CRLPublicationURLs ^
"65:C:\Windows\system32\CertSrv\CertEnroll\%3%8%9.cr1\n79:ldap:///CN=%7%8,CN=%2,CN
=CDP,CN=Public Key
Services,CN=Services,%6%10\n6:http://pki.corp.example.com/CertEnroll/%3%8%9.cr1\n6
5:file:///Srv1.corp.example.com/CertEnroll\%3%8%9.cr1"

certutil -getreg CA\CRLPublicationURLs
```



6.3 CA-Zertifikat und CRL veröffentlichen

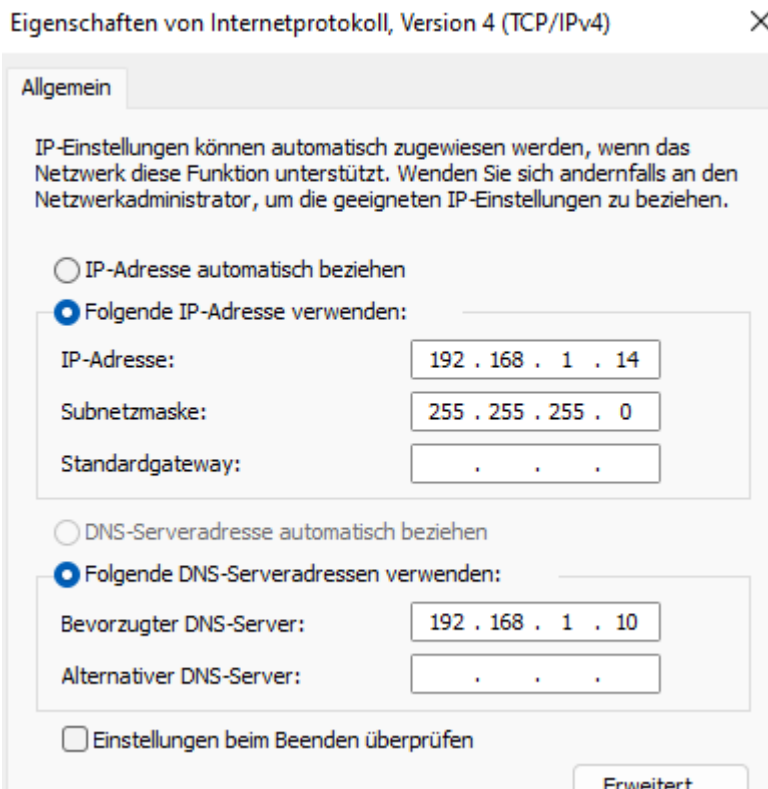
```
cd C:\Windows\System32\CertSrv\CertEnroll
copy "CA01.corp.example.com_corp-Root-CA.crt"
\\Srv1.corp.example.com\C$\CertEnroll
net stop certsvc && net start certsvc
```

Dann in `certsrv.msc`:

1. Rechtsklick auf „Widerrufene Zertifikate“ → **Alle Tasks** → **Veröffentlichen...**
2. „Neue CRL“ auswählen.

7. WIN01-Client in die Domäne aufnehmen

1. IP-Adressen konfigurieren so wie oben angeschrieben
2. Computernamen ändern + domain joinen
3. neustarten und dann mit dem Domain Admin anmelden



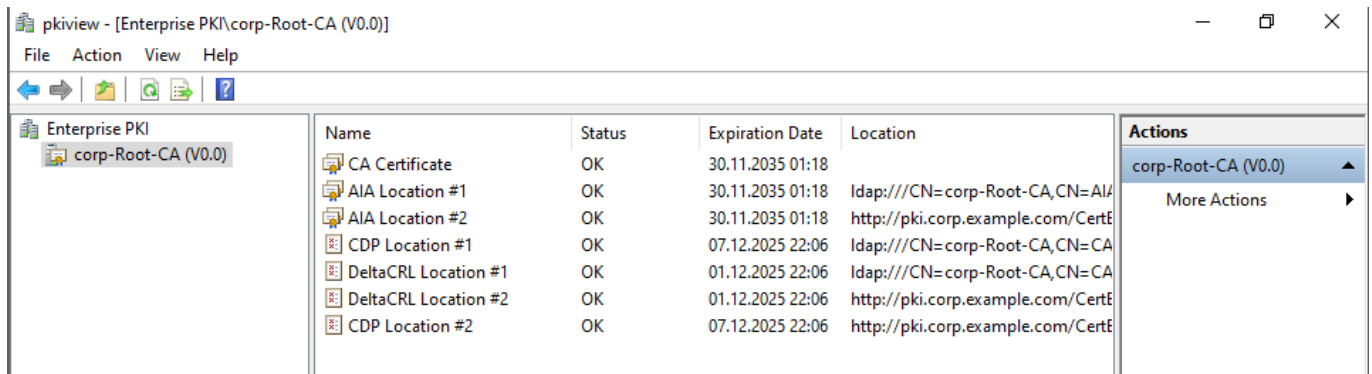
8. PKI-Gesundheit prüfen

8.1 Enterprise PKI (PKIView.msc)

Auf CA01:

1. `pkiview.msc` starten.
2. Unter „Enterprise PKI“ die **corp Root CA** auswählen.
3. Prüfen, dass CA-Zertifikat, AIA-URLs und CDP-URLs alle Status „OK“ anzeigen.

4. Auf **Enterprise PKI** rechtsklicken und dann über „Manage AD Containers“ die Einträge für NTAAuth, AIA, CDP etc. kontrollieren.



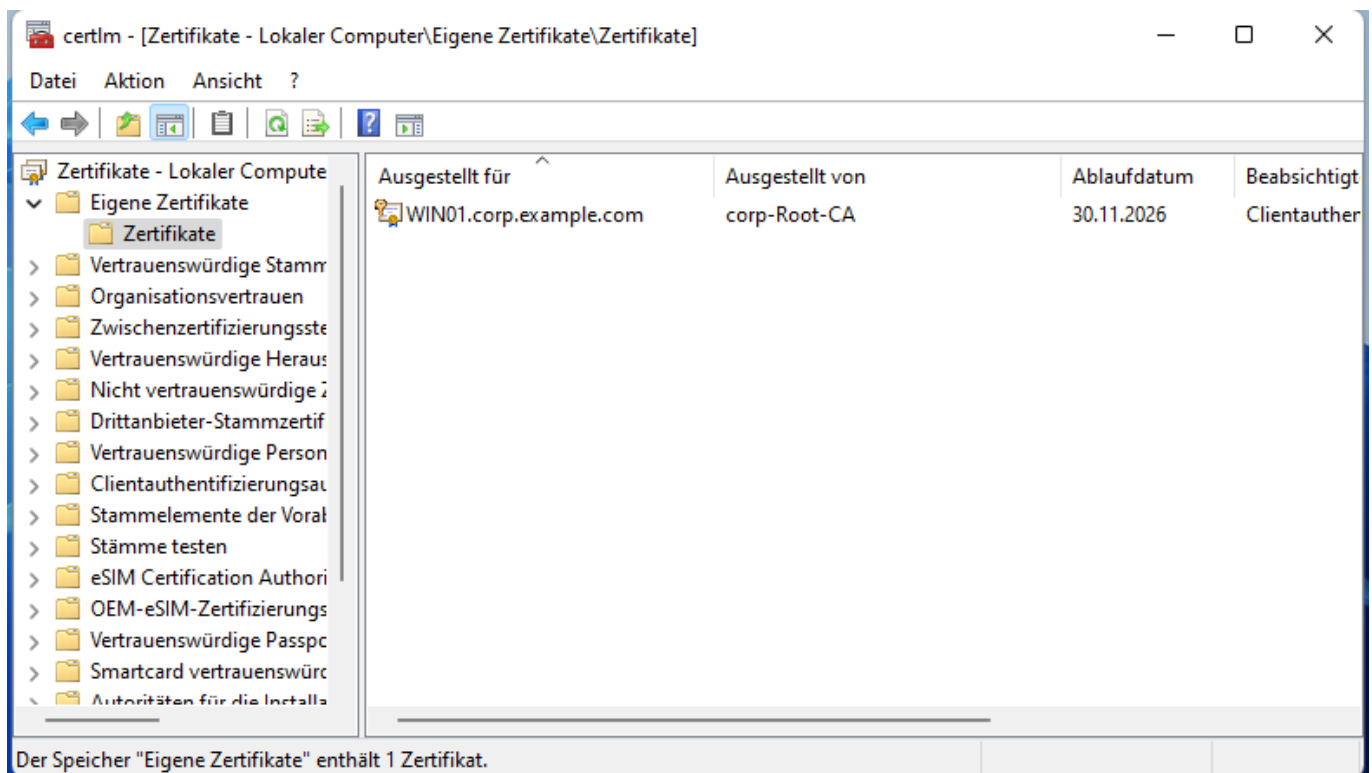
8.2 Testzertifikat einschreiben und prüfen

Auf CA01:

1. **certsrv.msc** öffnen.
2. Rechtsklick auf **Zertifikatvorlagen** → **Neu** → **Auszustellende Zertifikatvorlage**.
3. „Workstation Authentication“ auswählen.

Auf WIN01:

1. **mmc** starten → Snap-In „Zertifikate (Computerkonto)“ hinzufügen.
2. Unter **Persönlich** → **Zertifikate** → Rechtsklick → **Alle Tasks** → **Neues Zertifikat anfordern**.
3. „Active Directory-Richtlinie“ verwenden, „Workstation Authentication“ auswählen, einschreiben.

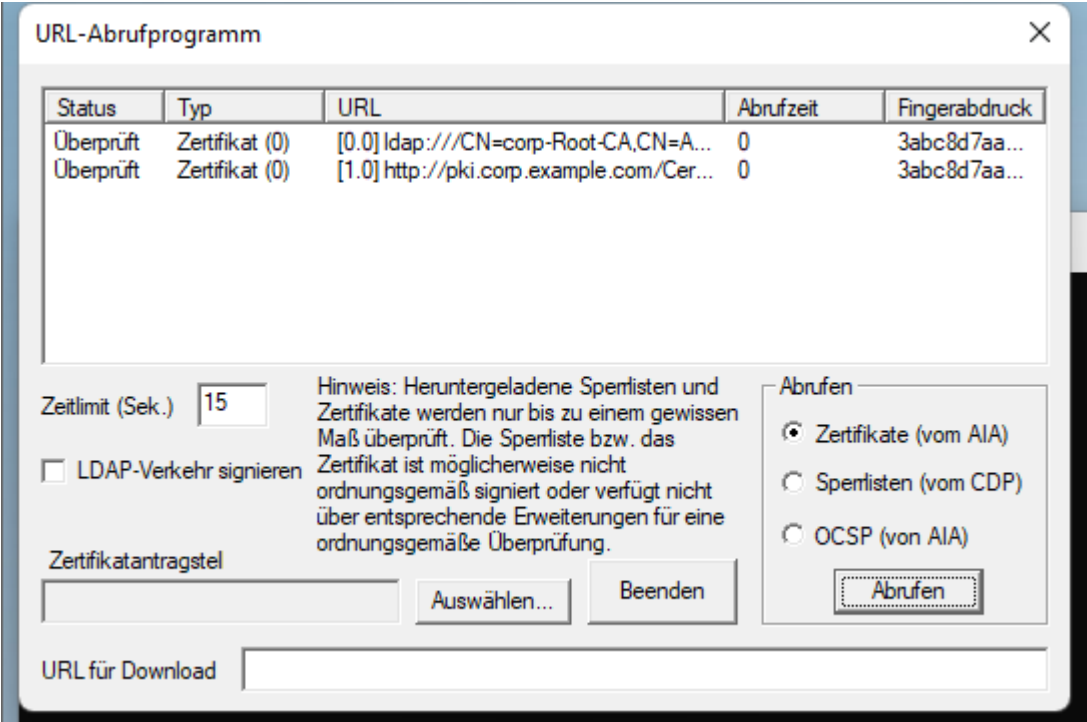
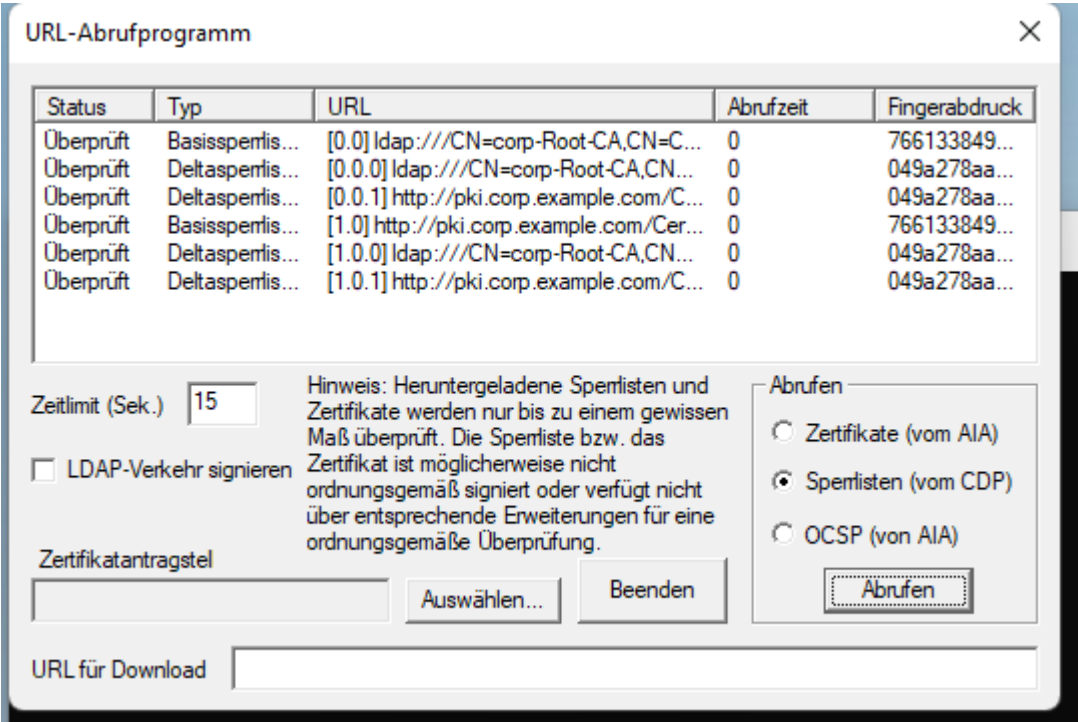


Zertifikat exportieren und prüfen:

1. **WIN01.corp.example.com**-Zertifikat ohne privaten Schlüssel als **C:\win01.cer** exportieren.
2. CMD als Admin:

```
cd \  
certutil -url C:\win01.cer
```

- 3. Zuerst „CRLs (from CDP)” → Retrieve → Status sollte „Verified” sein.
- 4. Dann „Certs (from AIA)” → Retrieve → ebenfalls „Verified”.
- 5. Danach:



```
certutil -verify -urlfetch C:\win01.cer
```

6. Ausgabe durchscrollen und prüfen, dass Kette und Sperrstatus erfolgreich verifiziert werden.